

00:00:03,869 --> 00:00:04,070 [speaker_0]

Hi.

00:00:04,160 --> 00:00:07,420 [speaker_1]

Hello, Sebastian. Nice background. [chuckles]

00:00:07,460 --> 00:00:12,180 [speaker_0]

Oh, wait, I was muted. Uh, yeah, same to you. [chuckles]

00:00:12,250 --> 00:00:13,860 [speaker_1]

It's good to see you again.

00:00:13,900 --> 00:00:23,280 [speaker_0]

Yeah, um, thank you so much, um, for taking your time, um, in participating in my interview. Actually helps a lot. Um, so-

00:00:23,290 --> 00:00:24,060 [speaker_1]

Definitely.

00:00:24,100 --> 00:00:42,100 [speaker_0]

Yeah. Um, I don't know, um, just for a heads-up, I, I, um, prepared around like, I don't know, seven questions, I guess. Um, so it shouldn't take, like, too long. Um, the half, half the hour would, um, uh, will be sufficient, I guess. Um, and-

00:00:42,110 --> 00:00:47,390 [speaker_1]

If we need to go a little bit over, I don't know about you, but I have till at least forty-five, fifty, um, so we're great.

00:00:47,400 --> 00:01:19,080 [speaker_0]

Oh, yeah, yeah. So yeah, that's great. So I have no meetings afterwards, uh, too, so yeah, perfect. Um, also, um, I wanted to mention to you, um, if there's, like, a question where you have, like, no idea what I want, [chuckles] or what the, what the question is aiming for, please, um, just tell me. Do not hesitate. Um, we can just skip and, and move on to the next question, so there is no, um, hassle in that. Um, yeah, I don't know if-- when you're ready, I'm ready. [chuckles]

00:01:19,090 --> 00:01:19,090 [speaker_1]

Yeah.

00:01:19,100 --> 00:01:20,320 [speaker_0]

And then we could just-

00:01:20,700 --> 00:01:20,840 [speaker_1]

No worries

00:01:20,860 --> 00:02:07,790 [speaker_0]

... um, start. Great! So let me just see where are my questions. I lost them on my screen. Um, yes, got it. All right, um, the first question is, when you hear the term, like this made-up term, audit-ready security report, um, what must an audit-ready security report, um, contain for you to accept it, like, as kind of reliable, or even to meet the definition of, of this term? So thinking about, like, um, the scope of the report, or like, the affected modules or vulnerabilities, responsibilities. Like, on the top of your head, um, what's an audit-ready security report for you? [chuckles]

00:02:08,680 --> 00:02:17,910 [speaker_1]

Yeah, I think, um, [clears throat] I'll just waffle a little bit about this. You know, I'm not a... This is one of those questions I don't wanna completely skip, but I'm certainly not the expert, so I don't know-

00:02:17,960 --> 00:02:18,120 [speaker_0]

Yeah

00:02:18,130 --> 00:02:35,980 [speaker_1]

... if that, like, weighs into your grading at all at the end, but I'll just self-reference it. But I think that, um, for me, like, best practice or, or kind of, um, you know, what I would a- advise for this piece would be looking at whatever the standard or regulatory compliance that you're trying to meet is.

00:02:36,160 --> 00:02:36,269 [speaker_0]

Mm-hmm.

00:02:36,269 --> 00:02:46,070 [speaker_1]

Um, and then I think that, like, audit-ready would mean a couple of different things, depending on if you're trying to actually be the security person who's working with the auditor to prove compliance-

00:02:46,100 --> 00:02:46,109 [speaker_0]

Mm-hmm

00:02:46,109 --> 00:02:50,489 [speaker_1]

... or whether it's more internal for your own team to be able to then prepare for that.

00:02:50,489 --> 00:02:50,489 [speaker_0]

Yeah.

00:02:50,520 --> 00:03:01,740 [speaker_1]

Because I think that [clears throat] in and of itself, an audit-ready report would be very difficult to generate without, like, usually it takes a lot of stakeholders from the team, right?

00:03:01,750 --> 00:03:01,750 [speaker_0]

True.

00:03:01,760 --> 00:03:02,480 [speaker_1]

Like, it's-

00:03:02,540 --> 00:03:02,680 [speaker_0]

Yeah

00:03:03,060 --> 00:03:08,860 [speaker_1]

... security, it's, um, you know, maybe some more of the technical people to make sure that everything is represented ready.

00:03:08,870 --> 00:03:08,950 [speaker_0]

Mm-hmm.

00:03:08,960 --> 00:03:12,570 [speaker_1]

Because when you go into one of those audits, it's like, just want this to go smoothly, and

you're-

00:03:12,600 --> 00:03:12,940 [speaker_0]

Yeah, yeah

00:03:12,950 --> 00:03:27,820 [speaker_1]

... working with configurers as well. So, um, yeah, I think that it would just be, depending on the, on the context, um, all of the information, evaluations, policy, procedure that goes into, um, determining, uh, if the system is safe and secure.

00:03:27,860 --> 00:03:28,090 [speaker_0]

Mm-hmm.

00:03:28,090 --> 00:03:31,380 [speaker_1]

But it really depends on the, the compliance you're trying to meet.

00:03:31,440 --> 00:04:26,700 [speaker_0]

Yeah, yeah, yeah. Yeah, um, good points. Um, so in from my perspective, these, um, these security reports, like the target group, is, um, probably like executives, um, or risk managers who like, um, have to make risk decisions based, um, on, on, on these, um, reports, or even as you mentioned, like, uh, third-party audits. Um, so yeah, that's, that's that. Um, yeah, I think we can move on to the, to the second question already. Um, yeah. Well, um, what kind of evidence makes statements about security credible to you, and what does not? So like, I don't know, measurements, um, like security metrics or, or anything like that, or policies, responsibilities, all that stuff.

00:04:26,760 --> 00:04:49,040 [speaker_1]

Yeah, that's a really good question. Um, credible. Um, I mean, I feel like a lot of times, uh, having some kind of statistical significance or variability baked in, like, to it, uh, sometimes when you go around and you talk to different vendors about their security products-

00:04:49,080 --> 00:04:49,180 [speaker_0]

Yeah

00:04:49,260 --> 00:04:52,380 [speaker_1]

... you know, they use very definitive terms, one hundred percent-

00:04:52,440 --> 00:04:52,630 [speaker_0]

Yeah [chuckles]

00:04:52,640 --> 00:04:57,920 [speaker_1]

... elimination, or things like this. And so that's kind of like a, a real giveaway that this person-

00:04:57,930 --> 00:04:57,930 [speaker_0]

Mm-hmm

00:04:57,930 --> 00:05:01,500 [speaker_1]

... isn't being, you know, as honest as they could be, and they're trying to sell a product.

00:05:01,510 --> 00:05:01,510 [speaker_0]

Yeah.

00:05:01,540 --> 00:05:05,540 [speaker_1]

So usually, a level of like nuance or skepticism or what have you-

00:05:05,900 --> 00:05:05,910 [speaker_0]

Mm

00:05:05,910 --> 00:05:10,840 [speaker_1]

... uh, and usually that's supported by some reasonable metrics. So that's kind of the first thing that I look at.

00:05:10,880 --> 00:05:11,260 [speaker_0]

Mm-hmm.

00:05:11,340 --> 00:05:15,780 [speaker_1]

Um, also thinking about credibility, and it's about, uh, security reports-

00:05:15,900 --> 00:05:15,910 [speaker_0]

Yep

00:05:15,910 --> 00:05:16,670 [speaker_1]

... in particular.

00:05:16,700 --> 00:05:17,100 [speaker_0]

Yep.

00:05:17,120 --> 00:05:26,960 [speaker_1]

Yeah. Mm, thoroughness, multiple testing methods, if that's appropriate. Um-

00:05:26,969 --> 00:05:27,050 [speaker_0]

Mm-hmm

00:05:27,050 --> 00:05:35,670 [speaker_1]

... there's usually, for any single thing that you care about, like two to three key metrics that you're gonna be like, attack success rate, detection rate, or what have you.

00:05:35,680 --> 00:05:35,830 [speaker_0]

Yeah.

00:05:35,840 --> 00:05:48,080 [speaker_1]

Right? And those are gonna be top of mind to look at from there, uh, or first of all, and then, uh, I guess from there, just like, yeah, the nuance and the description, the disclaimer about the limitations.

00:05:48,140 --> 00:05:48,740 [speaker_0]

Mm-hmm.

00:05:48,780 --> 00:05:49,900 [speaker_1]

Just-

00:05:49,920 --> 00:06:45,310 [speaker_0]

Yeah, great. Um, I also thought about, um, like, limitations, um, on the report, or like statements about limitations, um, from a security report or security product, um, which could be a thing. But I have a question for that later, so [chuckles] maybe we can-... um, figure that out later. Um, yeah, ne- the next question, um, is about the context. So in, in this audit reports,

um, if you would have to make a risk decision, um, how much context is necessary to make, uh, those, those risk decisions? Um, so-- or what context is helpful, like the, the affected modules or the business impact, um, so you could make, like, the best risk decision you would have to?

00:06:45,330 --> 00:06:49,590 [speaker_1]

Mm. Yeah, uh, could you give me a little bit more context for these?

00:06:49,600 --> 00:06:49,600 [speaker_0]

Okay.

00:06:49,670 --> 00:06:51,850 [speaker_1]

Uh, it might be helpful. I'm realizing maybe-

00:06:51,870 --> 00:06:51,880 [speaker_0]

Mm-hmm

00:06:51,880 --> 00:06:56,890 [speaker_1]

... like, I know we're a couple questions in, but, like, the top line of your project again, in terms of-

00:06:56,910 --> 00:06:56,920 [speaker_0]

Mm-hmm

00:06:57,290 --> 00:07:02,870 [speaker_1]

... for all these pieces, when I'm thinking about, um, like, the evaluation of what the-

00:07:02,890 --> 00:07:03,119 [speaker_0]

Mm-hmm

00:07:03,119 --> 00:07:04,770 [speaker_1]

... creation of the reports, to what end?

00:07:04,870 --> 00:07:05,390 [speaker_0]

Yeah, sure.

00:07:05,510 --> 00:07:07,360 [speaker_1]

Like, if you're-- e-even if it's kind of broad at this point or just a couple areas.

00:07:07,470 --> 00:07:32,290 [speaker_0]

Yeah, yeah. Um, so my, my research is about-- So I developed, um, like this tool, um, which tests new or new committed code to a code base, um, for vulnerabilities, like with static analysis tools and whatever. Um, and then compute some metrics like vulnerability density or, uh, like a severity matrix and, and all that stuff.

00:07:32,360 --> 00:07:32,360 [speaker_1]

Okay.

00:07:32,360 --> 00:08:21,740 [speaker_0]

And then that's like the measure part, um, of the risk management, uh, functions. Um, and then with some magic in the background, um, with those measure- measurements, um, it's mapped to like, um, certain responsibilities, um, or even risk holders or risk owners and, and whatever. Um, and then all of these inputs are generated in a, in a single report. Um, and I, I, I was just wondering... My, my last question actually is, um, where I would like to show you an actual

mock report. Um, so maybe we can move this question up, and I can show you the, uh, the report now, which makes it maybe more helpful for the, for the further questions. I don't know what you think.

00:08:21,740 --> 00:08:22,399 [speaker_1]

Yeah, that sounds really good.

00:08:22,410 --> 00:08:22,800 [speaker_0]

Yeah?

00:08:22,800 --> 00:08:22,800 [speaker_1]

Yeah.

00:08:22,850 --> 00:08:38,130 [speaker_0]

Okay. All right. Um, then I, I will send you a link. Um, I actually hosted it on a, on a, on a GitHub repository, so where you can, um, hopefully open it or see it, but I sh- think it should work.

00:08:39,049 --> 00:08:40,299 [speaker_1]

Awesome. Yeah! I see this. Yeah.

00:08:40,310 --> 00:09:08,190 [speaker_0]

All right. Yeah, perfect. So, um, if you, like, have a quick look about, or you can even take all the time you need. Um, when you see the report, what is, like, immediately helpful or what is missing or too technical? Because I got the feedback from, from the other [chuckles] interviews that it's, like, way too technical. Um, so if you would have to make a risk decic- decision based on this report, um, what's, what's your opinion about it? Or would you be able to make- [chuckles]

00:09:08,200 --> 00:09:08,200 [speaker_1]

Yeah

00:09:08,200 --> 00:09:11,090 [speaker_0]

... a risk decision based on this report?

00:09:11,210 --> 00:09:19,770 [speaker_1]

Yeah, so [clears throat] I think that this is a great report, uh, and that's why I was kind of talking about the context and the different people within the, the chain. So it depends on the-

00:09:19,790 --> 00:09:19,800 [speaker_0]

Yeah

00:09:19,800 --> 00:09:26,080 [speaker_1]

... organization, because sometimes if you're in a small enough organization, you'll get these people that are wearing multiple hats, and they-

00:09:26,090 --> 00:09:26,140 [speaker_0]

Mm-hmm

00:09:26,140 --> 00:09:29,870 [speaker_1]

... would be able to, like, look at this, and they're making the risk decision, what have you.

00:09:29,880 --> 00:09:29,890 [speaker_0]

Yeah.

00:09:29,910 --> 00:09:35,410 [speaker_1]

At any, like, larger Fortune five hundred company, this would be sitting with the security team, and then there's-

00:09:35,420 --> 00:09:35,420 [speaker_0]

Right

00:09:35,420 --> 00:09:38,380 [speaker_1]

... going to be a separate risk specialist who's going to, like-

00:09:38,390 --> 00:09:38,450 [speaker_0]

Mm

00:09:38,970 --> 00:09:41,020 [speaker_1]

... take this translated information-

00:09:41,310 --> 00:09:41,320 [speaker_0]

Mm

00:09:41,320 --> 00:09:46,510 [speaker_1]

... and then make some decisions with really, like, uh, uh, legal-

00:09:46,530 --> 00:09:46,560 [speaker_0]

Mm

00:09:46,560 --> 00:09:52,770 [speaker_1]

... in terms of, you know, um, you were asking about, like, is this enough information for you to be able to make a decision?

00:09:52,790 --> 00:09:53,590 [speaker_0]

Mm.

00:09:53,610 --> 00:09:59,480 [speaker_1]

The information that would be key here is in line with best practice, because for a lot of-

00:09:59,490 --> 00:09:59,500 [speaker_0]

Mm

00:09:59,500 --> 00:10:08,890 [speaker_1]

... folks, when they're deciding how much risk to take, it's like the, the thought, the general thought process is: If we get in trouble, will we be able-- would we get into legal trouble?

00:10:08,899 --> 00:10:08,899 [speaker_0]

Yeah.

00:10:08,899 --> 00:10:12,930 [speaker_1]

And the precedent for that is usually, did you comply with best practices and standards?

00:10:12,950 --> 00:10:13,010 [speaker_0]

Mm.

00:10:13,070 --> 00:10:20,080 [speaker_1]

And so what are other people in the industry doing? What was the compliance standard that I

had to meet, given NIST, given ISO-

00:10:20,090 --> 00:10:20,100 [speaker_0]

Yeah

00:10:20,100 --> 00:10:29,230 [speaker_1]

... given PCIe, IFFA, whatever. Uh, and so those numbers, whatever is key there, would be like the top line that I would wanna see-

00:10:29,270 --> 00:10:29,410 [speaker_0]

Okay

00:10:29,420 --> 00:10:31,610 [speaker_1]

... um, depending on what it is I'm trying to meet, right?

00:10:31,910 --> 00:10:32,140 [speaker_0]

Mm-hmm.

00:10:32,140 --> 00:10:39,390 [speaker_1]

This seems pretty good. Like, we have some information on the clusters. We have, I don't know what, like, weak crypto. Oh, I can click in.

00:10:39,430 --> 00:10:39,890 [speaker_0]

Yeah, yeah.

00:10:39,930 --> 00:10:40,140 [speaker_1]

Uh- [chuckles]

00:10:40,140 --> 00:10:42,210 [speaker_0]

That's like a gimme. [chuckles]

00:10:42,310 --> 00:10:50,170 [speaker_1]

I like that. In cryptography... Yeah, I mean, like, this would all be super useful information to a security person who maybe needs to-

00:10:50,210 --> 00:10:50,370 [speaker_0]

Mm

00:10:50,430 --> 00:10:52,910 [speaker_1]

... resolve or mitigate them in some ways.

00:10:52,920 --> 00:10:52,920 [speaker_0]

Mm.

00:10:52,950 --> 00:11:04,100 [speaker_1]

But in terms of, uh, um, and maybe this, you know, again, it goes hand in hand, but like, if I have to make some kind of risk decision, I would want prioritization and more of the business context.

00:11:04,110 --> 00:11:04,280 [speaker_0]

Okay.

00:11:04,290 --> 00:11:12,800 [speaker_1]

Like, you do have high, medium, uh, but that kind of tells me about the security risk, not about-

00:11:12,830 --> 00:11:12,910 [speaker_0]

Mm

00:11:12,990 --> 00:11:15,290 [speaker_1]

... maybe the actual risk of compromise.

00:11:15,370 --> 00:11:15,730 [speaker_0]

I see, yeah.

00:11:15,740 --> 00:11:22,220 [speaker_1]

And so somebody would say, like: "Okay, well, we know 'cause we're in this industry that, like, SQL injection is top of mind.-

00:11:22,220 --> 00:11:22,220 [speaker_0]

Mm.

00:11:22,220 --> 00:11:23,270 [speaker_1]

-Like, we just need to-

00:11:23,290 --> 00:11:23,360 [speaker_0]

Yeah, yeah

00:11:23,360 --> 00:11:24,060 [speaker_1]

... prevent that."

00:11:24,190 --> 00:11:24,230 [speaker_0]

Yeah.

00:11:24,250 --> 00:11:26,840 [speaker_1]

So then that would get high risk, too. Yeah, you feel me?

00:11:26,840 --> 00:11:27,120 [speaker_0]

Mm-hmm.

00:11:27,130 --> 00:11:30,210 [speaker_1]

So yeah, that's pretty much it. But I mean, I think this looks great. It's just-

00:11:30,230 --> 00:11:30,470 [speaker_0]

Thank you

00:11:30,510 --> 00:11:33,070 [speaker_1]

... those pieces of context and translation-

00:11:33,090 --> 00:11:33,100 [speaker_0]

Yeah

00:11:33,100 --> 00:11:35,140 [speaker_1]

... would be more for a risk manager.

00:11:35,150 --> 00:12:04,370 [speaker_0]

Yeah, yeah, yeah. I see. Also, I, I think the point you mentioned is great for, like, big companies

where, like, there's a whole bunch of security guys. Um, the, the report would probably be easy to understand or easy to read, but if I th- think, like, smaller companies, um, where a risk owner or like, I don't know, risk manager is not, like, that familiar with security, it might be hard, um, to understand, like, the very technical stuff in the, in the report. Um-

00:12:04,490 --> 00:12:05,570 [speaker_1]

Right. Yeah.

00:12:05,610 --> 00:13:04,386 [speaker_0]

Yeah. Great. Um..... So I don't know if you can recall, but my, my, my, so my research is also about, like, the AI-generated code, so that was, like, the, the whole idea or, or like the whole point, because as you know, like, I would say, I don't know, probably more than fifty percent of the code is actually, like, vibe coded right now, or probably, probably even more. Um, and that's, that's like the, the huge problem in the software development, um, processes there are. Um, so would you or how would you use, like, the provenance, um, of the codes in the report? Like, if, if the, the, the tested code is, like, fully vibe coded or artificially generated or whatever, would you mention that in the report, um, at all, or would you leave it out? Um, what's your, what's your opinion about it?

00:13:05,306 --> 00:13:06,916 [speaker_1]

Probably would leave that information out.

00:13:06,966 --> 00:13:06,976 [speaker_0]

Okay.

00:13:07,026 --> 00:13:11,546 [speaker_1]

I think for a lot of developers and in practice, it's- they just want the bottom line.

00:13:11,566 --> 00:13:11,586 [speaker_0]

Mm.

00:13:11,606 --> 00:13:14,306 [speaker_1]

Like, did this introduce more, you know-

00:13:14,326 --> 00:13:14,336 [speaker_0]

Mm

00:13:14,336 --> 00:13:15,596 [speaker_1]

... bugs or, um-

00:13:15,606 --> 00:13:15,826 [speaker_0]

I see

00:13:15,846 --> 00:13:23,246 [speaker_1]

... latency or whatever it is they care about, more than... And even at the risk level, right? Like, you probably wanna leave that out of your reporting. [chuckles]

00:13:23,256 --> 00:13:26,426 [speaker_0]

Yeah, yeah. Also, if it gets, like, audited and all the reports-

00:13:26,606 --> 00:13:26,656 [speaker_1]

Mm

00:13:26,656 --> 00:13:33,426 [speaker_0]

... um, are stating, like, everything is AI generated, it m- might not be the best image.
[chuckles]

00:13:33,446 --> 00:13:33,866 [speaker_1]

Yeah.

00:13:33,886 --> 00:13:34,076 [speaker_0]

Yeah. I think, yeah.

00:13:34,086 --> 00:13:38,586 [speaker_1]

But if they have to, like, if that was a requirement of reporting, then obviously keeping track of that-

00:13:38,596 --> 00:13:38,596 [speaker_0]

Yeah, sure

00:13:38,596 --> 00:13:40,016 [speaker_1]

... would be it. Yeah.

00:13:40,066 --> 00:14:01,186 [speaker_0]

I see. Mm. Um, all right. We're actually pretty quick. Um, that's good. The next question is... Yeah, now it's about limitations. So, um, how should a report make its limitations or uncertainties transparent without losing trust? Um, for e- for example, like-

00:14:01,206 --> 00:14:01,216 [speaker_1]

Mm

00:14:01,216 --> 00:14:12,266 [speaker_0]

... if there's, like, known blind spots from my, my coded tool or, um, some limitations or false positives, um, how would you include that in the report?

00:14:14,046 --> 00:14:22,266 [speaker_1]

Yeah. I think metrics are really good, any amount of uncertainty, however, it's best able... Yeah, and most appropriate to represent that.

00:14:22,286 --> 00:14:22,446 [speaker_0]

Mm.

00:14:22,486 --> 00:14:28,136 [speaker_1]

Um, I also think that, you know, some more context around some of these things, like the medium-high-

00:14:28,146 --> 00:14:28,176 [speaker_0]

Okay. Yeah, mm

00:14:28,176 --> 00:14:40,826 [speaker_1]

... how you come to that determination. Um, I just think overall, like, it only strengthens the overall view of your report to have error bars, to have extra information, and to whenever you can, like, caveat or-

00:14:40,926 --> 00:14:41,006 [speaker_0]

Mm

00:14:41,166 --> 00:14:45,066 [speaker_1]

... think about the limitations. I don't think that will make somebody less likely to use it.

00:14:45,086 --> 00:14:45,096 [speaker_0]

Mm.

00:14:45,106 --> 00:14:46,775 [speaker_1]

I think it'll make them more likely to use it.

00:14:46,786 --> 00:14:47,066 [speaker_0]

Yeah.

00:14:47,086 --> 00:14:47,236 [speaker_1]

Yeah.

00:14:47,246 --> 00:15:24,446 [speaker_0]

Yeah, I see. Perfect. Um, then I only have two questions left, I guess. Uh, yeah, one question we skipped is, um, like, what responsibility information do you need to clarify risk ownership? Um, like, is, is it helpful to have, like, an owner per system or per component on the report, or like, one general risk manager or, like, um, a responsibility, responsibility matrix or escalation roles? Um, yeah, that's like-

00:15:24,526 --> 00:15:25,946 [speaker_1]

In this kind of report-

00:15:26,266 --> 00:15:26,326 [speaker_0]

Yeah

00:15:26,336 --> 00:15:33,616 [speaker_1]

... you're asking if it's a, to have that? Um, I would think not, given-

00:15:33,766 --> 00:15:33,775 [speaker_0]

Okay

00:15:33,775 --> 00:15:40,066 [speaker_1]

... what you're trying to do. I don't know that adding extra information about the organization and who owns what in a report-

00:15:40,086 --> 00:15:40,096 [speaker_0]

Mm

00:15:40,096 --> 00:15:42,786 [speaker_1]

... like this really-

00:15:43,546 --> 00:15:44,215 [speaker_0]

Yeah, it would just-

00:15:44,306 --> 00:15:44,696 [speaker_1]

Strengthen or help

00:15:44,696 --> 00:15:47,546 [speaker_0]

... blow up the report too much. I see.

00:15:47,606 --> 00:15:48,026 [speaker_1]

Yeah.

00:15:48,046 --> 00:16:34,906 [speaker_0]

Mm. Um, all right, then the last question already. Um, so given my, my mock report, um, what do you say about the, the, the structure or the arrangement of the sections? Are they... Is it, like, properly arranged, or would you, like, move parts around? Like, the vulnerabilities are pretty much at the bottom right now. Would you, like, move that up to the top? Like, probably not above the executive summary. That's, like, probably always the, the top thing in a report, but, um, yeah. What, what are your thoughts about... Or also, would you, like, keep the, the clicky part so that you have to expand, um, the vulnerabilities, or would you leave it, like, with this, uh, header line or... Yeah.

00:16:36,286 --> 00:16:38,046 [speaker_1]

Yeah. I like being able to click in.

00:16:38,166 --> 00:16:38,216 [speaker_0]

[chuckles] Perfect.

00:16:38,216 --> 00:16:43,926 [speaker_1]

That's nice. I would move the, uh, the vulnerabilities just below the executive summary, and-

00:16:44,046 --> 00:16:44,246 [speaker_0]

Okay

00:16:44,486 --> 00:16:53,966 [speaker_1]

... maybe there's even a way that you determine how to prioritize those. So like, if there's twenty high vulnerabilities, I just take the top five, but if there's only three-

00:16:53,986 --> 00:16:53,996 [speaker_0]

Mm

00:16:53,996 --> 00:16:54,526 [speaker_1]

... overall-

00:16:54,536 --> 00:16:55,236 [speaker_0]

Ah, yeah, good point. Yeah

00:16:55,236 --> 00:16:58,606 [speaker_1]

inklusive. Yeah.

00:16:58,626 --> 00:16:59,926 [speaker_0]

Yeah, because I think right now-

00:16:59,986 --> 00:17:01,586 [speaker_1]

That's kind of the... No, go ahead.

00:17:01,626 --> 00:17:13,506 [speaker_0]

Yeah, yeah, yeah, because, uh, I just thought about what you said. It's like, if, if there would be, like, one hundred vulnerabilities, all the one hundred vulnerabilities would be, um, in the report right now. So that's a very good point. Yeah.

00:17:14,986 --> 00:17:19,346 [speaker_1]

Yeah. And a lot of times, you know, like, it's almost kind of a mini executive summary, right?

00:17:19,366 --> 00:17:19,376 [speaker_0]

Mm.

00:17:19,386 --> 00:17:22,766 [speaker_1]

You have these different steps, and then you would have, like, maybe your top five-

00:17:22,826 --> 00:17:23,466 [speaker_0]

Mm. Yeah

00:17:23,846 --> 00:17:27,466 [speaker_1]

... bulbs, and then I know exactly what I need to look at next.

00:17:27,506 --> 00:17:43,546 [speaker_0]

Mm. And the top, like, let's stick to the top five, um, based on what criteria? Like, um, the severity, like, hard or medium, or ba, um, based on the business impact? Um, what, what, what would be the criteria for you?

00:17:45,706 --> 00:17:46,766 [speaker_1]

Yeah, that's really tough.

00:17:46,776 --> 00:17:46,776 [speaker_0]

Yeah.

00:17:46,806 --> 00:17:52,456 [speaker_1]

I think that being doing a lot of, uh, risk management is how to prioritize, how to rank these different things.

00:17:52,456 --> 00:17:52,466 [speaker_0]

Yeah.

00:17:52,486 --> 00:18:08,246 [speaker_1]

So there's kind of, like you're saying, you're, you're thinking about all the right stuff. I don't know what the, um, right thing to focus on is for you. The business context is tough, but it's also-

00:18:08,286 --> 00:18:08,296 [speaker_0]

Mm

00:18:08,296 --> 00:18:12,446 [speaker_1]

... kind of essential. So I think one of the main complaints that I hear-

00:18:12,466 --> 00:18:12,476 [speaker_0]

Okay

00:18:12,476 --> 00:18:20,536 [speaker_1]

... sometimes, um-... amongst security folks is that: Okay, well, we assigned all these CVEs, and now, like, everything is severe.

00:18:20,646 --> 00:18:20,656 [speaker_0]

Mm-hmm.

00:18:20,656 --> 00:18:30,086 [speaker_1]

And, you know, in reality, nobody's actually going to exploit this, and there's bits and pieces.

And so you have that camp of people that will always kinda have that great-- But then it's like: Well, what is the solution?

00:18:30,096 --> 00:18:30,096 [speaker_0]

Mm.

00:18:30,146 --> 00:18:32,516 [speaker_1]

I don't know what sector you're in. I don't know your-

00:18:32,526 --> 00:18:32,566 [speaker_0]

Right

00:18:32,576 --> 00:18:33,296 [speaker_1]

-business context-

00:18:33,326 --> 00:18:33,376 [speaker_0]

Yeah

00:18:33,386 --> 00:18:38,376 [speaker_1]

-obviously, when I'm reporting those types of things, uh, unless you have some way to kinda feed that in, which-

00:18:38,446 --> 00:18:38,456 [speaker_0]

Yeah

00:18:38,456 --> 00:18:40,486 [speaker_1]

-complicates your project a ton-

00:18:40,496 --> 00:18:40,496 [speaker_0]

Mm

00:18:40,496 --> 00:18:42,216 [speaker_1]

-and takes the focus away from probably what-

00:18:42,246 --> 00:18:42,256 [speaker_0]

Yeah

00:18:42,256 --> 00:18:50,036 [speaker_1]

-you wanna focus on. But then there's also, like, I guess, some amount of threat intel information that might be interesting-

00:18:50,146 --> 00:18:50,156 [speaker_0]

Mm-hmm

00:18:50,156 --> 00:18:59,586 [speaker_1]

... in terms of like, you know, uh, of the-- if you could get some data on how people are, uh, exploiting a particular AI-generated code-

00:18:59,606 --> 00:18:59,635 [speaker_0]

Mm-hmm

00:18:59,686 --> 00:19:01,056 [speaker_1]

... and the kind of vulnerabilities-

00:19:01,066 --> 00:19:01,076 [speaker_0]

Mm

00:19:01,076 --> 00:19:10,076 [speaker_1]

-that have been... You know, something like, uh, I-- OWASP, I don't think has anything specifically about secure code or, like, AI-generated code.

00:19:10,106 --> 00:19:10,366 [speaker_0]

Yeah.

00:19:10,466 --> 00:19:22,126 [speaker_1]

Um, so, uh, maybe there is something, though, that's just like top ten for, I don't know, uh, these different things in general.

00:19:22,136 --> 00:19:22,136 [speaker_0]

Yeah.

00:19:22,146 --> 00:19:24,806 [speaker_1]

There, there are OWASP top ten in general. Um, but-

00:19:24,826 --> 00:19:26,126 [speaker_0]

I see.

00:19:26,166 --> 00:19:33,196 [speaker_1]

Yeah, yeah. I don't know if you wanna split it by like: okay, you have these bones, and then, uh, if you also are worried about API security or-

00:19:33,226 --> 00:19:33,246 [speaker_0]

Yeah

00:19:33,256 --> 00:19:34,206 [speaker_1]

-application security or-

00:19:34,226 --> 00:19:34,236 [speaker_0]

Yeah

00:19:34,236 --> 00:19:36,806 [speaker_1]

-these different things, there's a couple different ways that you could do it-

00:19:36,826 --> 00:19:36,846 [speaker_0]

Mm

00:19:36,886 --> 00:19:45,286 [speaker_1]

... if you want to lean into that. Um, but I think that this is perfectly fine as is by just going to like, you know, yeah, what is ranked, uh, as most-

00:19:45,326 --> 00:19:45,386 [speaker_0]

Okay

00:19:45,526 --> 00:19:52,146 [speaker_1]

-severe? What, what do these have, uh, as just a baseline. And then after that, like, all the things you're talking about are good to consider, but-

00:19:52,166 --> 00:19:52,246 [speaker_0]

Mm

00:19:52,266 --> 00:19:55,446 [speaker_1]

... it's just the extent that you can find good information.

00:19:55,486 --> 00:19:55,646 [speaker_0]

Yeah.

00:19:55,686 --> 00:19:55,996 [speaker_1]

Yeah.

00:19:56,046 --> 00:20:06,226 [speaker_0]

Yeah, yeah. All right. Um, that was actually perfect. Um, I think we're through.

00:20:06,286 --> 00:20:06,846 [speaker_1]

All right.

00:20:06,946 --> 00:20:08,086 [speaker_0]

Saved a lot of time.

00:20:08,096 --> 00:20:08,126 [speaker_1]

Awesome.

00:20:08,146 --> 00:20:20,526 [speaker_0]

Yeah, awesome. Re- re- really. So, yeah, thank you so much for your, um, answers. [chuckles]
Um, yeah, I will mention you in my thesis, of course. [chuckles]

00:20:20,546 --> 00:20:25,946 [speaker_1]

Awesome, and I wish you the best of luck for that. Um, if there's anything else I can do to be helpful, just let me know. And, um-

00:20:25,966 --> 00:20:26,366 [speaker_0]

Yeah, thank you.

00:20:26,375 --> 00:20:29,426 [speaker_1]

Yeah, and definitely let me know when it's, uh, published. I'd love to give it a read, too.

00:20:29,466 --> 00:20:35,296 [speaker_0]

Perfect. Yeah, I will let you know. Um, so yeah, I wish you a nice day. [chuckles]

00:20:35,306 --> 00:20:36,006 [speaker_1]

Yeah, same. All right.

00:20:36,046 --> 00:20:36,375 [speaker_0]

Perfect.

00:20:36,406 --> 00:20:36,466 [speaker_1]

Bye-bye.

00:20:36,476 --> 00:20:49,526 [speaker_0]

Thank you. Bye.